Kirin Feng

City: Richmond • E-mail: fengyuanqi@gmail.com • Phone: 7789668194
LinkedIn: https://www.linkedin.com/in/kirin-feng/ • Portfolio: https://kirinfeng.github.io/Portfolio/

Summary

Cybersecurity graduate with hands-on experience in application security, vulnerability assessment, threat modeling, digital forensics, and security detection. Applied tools and frameworks including Burp Suite, OWASP ZAP, Nmap, Suricata, Sysmon, STRIDE, and Autopsy across penetration testing, secure software engineering, and forensic projects. Seeking Security Analyst, Application Security, or Junior Security Engineer opportunities.

Technical Skills

Security & Assessment: Nmap, Burp Suite, WebGoat, Fiddler, Penetration testing, vulnerability exploitation, Metasploit, SQLMap, SMB enumeration, OWASP ZAP, Wapiti, DVWA, DIRB, IDA Freeware, Angry IP Scanner, vulnerability assessment, web application security, HTTP interception and analysis
Threat Detection & Analysis: MITRE ATT&CK, Suricata, PCAP analysis, IDS rule development, Sysmon, Wireshark, network traffic analysis, log analysis, CVE analysis, exploit detection, indicators of compromise
Web Application Security: SQL Injection, XSS, IDOR/BOLA, Broken Access Control, authentication testing, business logic testing, HTTP request manipulation
Security Engineering: STRIDE, data flow diagrams, trust boundaries, OWASP SAMM, BSIMM, secure SDLC, threat modeling, API security, authentication and authorization, tenant isolation, risk assessment
Cryptography & PKI: AES, RSA, ECC, Diffie-Hellman, SHA-256/SHA-3, HMAC, digital signatures, PKI, X.509 certificates, TLS/HTTPS; hands-on with OpenSSL, CA/CSR workflows, certificate issuance, and certificate validation
Digital Forensics: Autopsy, FTK Imager, file carving, raw binary analysis, file signatures, E01 disk images, Windows artifacts, browser history analysis, filesystem analysis, evidence integrity, MD5/SHA hash verification, forensic reporting; academic exposure to Volatility, Scalpel, Guymager, dd, and dc3dd
Identity & Access Management: Active Directory, AD DS, Organizational Units, Security Groups, RBAC, Domain Administration, Windows Permissions
Blockchain & Smart Contracts: Solidity, Ethereum, Sepolia Testnet, Remix, MetaMask, Smart Contract Development
Systems & Networking: Linux, Windows, Kali Linux,Windows Server, TCP/IP, Cisco networking, VirtualBox, Cisco Packet Tracer, PowerShell, network troubleshooting
Programming Languages & Platforms: Python, Java, JavaScript, C++, PHP, SQL, HTML, CSS, Assembly language, Visual Basic, Classic Visual Basic, Docker
Databases & Tools: MySQL, PostgreSQL, Microsoft Access, Tableau, MATLAB, GitHub, Visual Studio, Eclipse, Processing, Microsoft Project, StarUML

Relevant Experience

Website Developer | January 2023 – August 2023
New Field Education Group – Vancouver, BC

- Supported the development and maintenance of the website functionality and user-facing content using HTML, CSS, JavaScript, and related web technologies.
- Translated business and user requirements into practical website updates, coordinated feedback with stakeholders, and supported testing and issue resolution.
- Resolved website issues and improved usability and consistency across desktop and mobile platforms.
- Improved website presentation through structured page layouts, consistent styling, and iterative quality assurance on different platforms.

Business Development Advisor | January 2021 – August 2021
Quantasphere Solution – Burnaby, BC

- Supported business development planning, client communication, and opportunity evaluation by organizing requirements and preparing practical recommendations.

- Coordinated with stakeholders to clarify priorities, track deliverables, and align technical or service activities with business objectives.
- Contributed research, documentation, and presentation support for decision-making and relationship development.

Cybersecurity & Technical Projects

Authorized Web Application Penetration Test – *Graduate Industry Client Partner Project*
Nmap | Nessus Essentials | Burp Suite | DIRB | JWT Security Testing | Python | Web Application Security

- Conducted an authorized external penetration test on two web application environments, building an asset, service, and version baseline while mapping the attack surface through network, web, and client-side analysis.
- Used Nmap, Nessus Essentials, Burp Suite, DIRB, JWT analysis, and Python-based source-map review to validate findings across authentication, access control, exposed services, security headers, file upload handling, and dependency risk.
- Reconstructed 76 client-side source files from an exposed Webpack source map to assess source code disclosure, route and API exposure, and business logic leakage risk.
- Delivered prioritized remediation guidance for JWT signature verification, server-side authorization, source-map restriction, dependency patching, firewall rules, secure upload controls, and HTTP security headers.

CVE-2022-1388 Exploit & Detection Analysis - *Graduate Intrusion Detection Project*
F5 BIG-IP | Authentication Bypass | RCE | Wireshark | Suricata | Sysmon | MITRE ATT&CK

- Reproduced CVE-2022-1388 authentication-bypass and remote-code-execution behavior against a simulated F5 BIG-IP iControl REST endpoint in an isolated lab using crafted HTTPS POST requests, then validated command execution and file-system impact.
- Correlated Wireshark traffic with server logs, mapped activity to MITRE ATT&CK techniques including T1190, T1059.004, and T1071.001, and developed Suricata/Sysmon detection logic plus mitigation recommendations.

Network Reconnaissance, Exploitation & IDS Detection – *Graduate Intrusion Detection Project*
Nmap | Metasploit | Suricata | Wireshark | SMB/Samba | Nmap NSE | Meterpreter | PCAP Analysis

- Performed network reconnaissance and attack-surface enumeration using Nmap host discovery, TCP/SYN scanning, OS and service version detection, NSE scripts, and alternative scan techniques against an isolated lab environment.
- Enumerated exposed SMB services and user information, analyzed available shares, and used the Metasploit Framework to reproduce a Samba remote-code-execution scenario and obtain a Meterpreter session on the lab target.
- Analyzed captured network traffic in Wireshark and configured Suricata as a network intrusion detection system, including rule-set updates, network variables, and custom local detection rules.
- Developed and validated Suricata signatures for malicious HTTP/XSS traffic, detecting patterns including <script>, alert(), onerror, and eval() across captured PCAP traffic.

Web Application Exploitation & Access Control Testing – *Graduate Intrusion Detection Project*
Burp Suite | Docker | SQLMap | XSS | IDOR | SQL Injection | Broken Access Control | HTTP Manipulation

- Deployed an intentionally vulnerable web application using Docker and configured Burp Suite as an intercepting proxy to inspect and manipulate HTTP requests and application parameters.
- Exploited authorization and business-logic weaknesses including IDOR, client-side price manipulation, unauthorized profile/review modification, and broken access-control scenarios by modifying object identifiers and request parameters.
- Tested stored XSS and information-disclosure vulnerabilities, including unsafe user-controlled content and sensitive resource exposure through application configuration and accessible files.
- Analyzed authentication and account-recovery weaknesses involving user-controlled identity attributes and workflow bypasses, demonstrating potential account-takeover conditions in the controlled lab environment.
- Performed blind SQL injection testing using intercepted HTTP requests and SQLMap to identify injectable parameters and demonstrate database-level security impact.

Software Security Assessment & STRIDE Threat Modeling – *Graduate Team Project*
OWASP Threat Dragon | STRIDE | Data Flow Diagrams | Threat Modeling | API Security | Microservices | Kubernetes | Secure SDLC

- Modeled the security architecture of a multi-tenant e-commerce SaaS platform consisting of a web/mobile SPA, REST API Gateway, authentication, order and payment microservices, managed SQL/object storage, and third-party payment and logistics integrations.
- Built a Level 0 Data Flow Diagram (DFD) in OWASP Threat Dragon, defining external entities, processes, data stores, data flows, and trust boundaries across the application and cloud service architecture.
- Applied STRIDE threat modeling to identify 23 security threats, including 5 Critical, 12 High, and 6 Medium-severity risks, covering spoofing, tampering, repudiation, information disclosure, denial of service, and privilege escalation.
- Analyzed high-risk scenarios including JWT/session token compromise, broken object-level authorization (BOLA/IDOR), cross-tenant access, client-side parameter tampering, forged payment webhooks, insufficient audit logging, and API resource exhaustion.
- Developed risk-based mitigations including centralized authorization, server-side tenant isolation, JWT validation, webhook signature verification, rate limiting, secure logging, input validation, and automated security testing.

Software Security Assessment & Threat Modeling – *Graduate Team Project*
OWASP SAMM | BSIMM | STRIDE | DFD | Microservices | Secure SDLC

- Assessed the software security maturity of a simulated multi-tenant e-commerce SaaS organization using OWASP SAMM and a BSIMM quick survey.
- Identified material gaps in governance, secure build practices, defect management, and incident management.
- Designed data flow diagrams for 7 major system components: a customer SPA, merchant dashboard, API gateway, authentication, order, checkout, and payment services and explicit trust boundaries across microservices, managed data stores, and third-party integration.
- Prioritized risks using severity and likelihood assessments to analyze spoofing, tampering, repudiation, information disclosure, denial-of-service, and privilege-escalation scenarios, with emphasis on API access control and tenant isolation.
- Developed a prioritized security roadmap covering standardized authentication and authorization, CI/CD security checks, monitoring, vulnerability testing, governance, and incident response; used OWASP Cornucopia to reinforce secure-design analysis.

Linux Operating System Security & Exploitation Lab – *Graduate Academic Project*
Linux | ACL | SUID | GDB | strace | GCC | Buffer Overflow | Access Control | Privilege Escalation

- Configured and validated fine-grained Linux Access Control Lists (ACLs) using setfacl and getfacl, implementing user-specific read, write, execute, and directory-access restrictions across multiple accounts and files.
- Analyzed SUID-based privilege escalation risks using Linux file permissions, strace, system-call tracing, and PATH behavior, and evaluated mitigations including absolute command paths and privilege dropping.
- Investigated a stack-based buffer overflow in a privileged C application caused by unsafe strcpy() usage, triggering memory corruption with oversized input and analyzing program behavior using GDB.
- Examined stack memory and attacker-controlled input at runtime to validate buffer-overflow conditions and assessed potential risks involving control-flow manipulation and privilege escalation.

Public Key Infrastructure & HTTPS Security Lab – *Graduate Cryptography Project*
OpenSSL | PKI | X.509 | RSA | SHA-256 | TLS/HTTPS | Apache | Linux

- Built a private PKI using OpenSSL by creating a Certificate Authority, generating RSA key pairs and Certificate Signing Requests (CSRs), and issuing CA-signed X.509 server certificates.
- Deployed certificate-based HTTPS on Apache and configured SSL VirtualHosts, certificate and private-key paths, local hostname resolution, and browser CA trust.
- Tested certificate validation through untrusted CA warnings, hostname/IP mismatches, modified key material, and controlled man-in-the-middle scenarios involving untrusted and compromised Certificate Authorities.

Python File Carving Tool – *Graduate Digital Forensics Project*

Python | File Carving | Raw Data Analysis | File Signatures | FTK Imager | MD5/SHA-256

- Developed a Python-based file carving prototype that scans raw binary data and .dd disk images for header and footer signatures to recover JPEG, PNG, and PDF files without relying on file system metadata.
- Implemented modular signature dictionaries, byte-offset-based output naming, and automated recovery into a structured output directory to support traceability and repeatable forensic analysis.
- Validated recovered non-fragmented files by opening outputs and comparing MD5/SHA-256 hashes against original sources; documented limitations involving fragmented files, missing footers, and large forensic image memory usage.

Digital Forensics Investigation Using Autopsy – *Graduate Academic Project*
Autopsy | E01 | Windows Forensics | Hash Verification | Evidence Reporting

- Conducted a structured investigation of a Windows E01 forensic image in Autopsy and validated image integrity using available cryptographic acquisition hashes.
- Examined Windows user-account artifacts, browser history, filesystem records, and user-generated files to reconstruct activity and answer defined investigative questions.
- Collected, correlated, and documented digital evidence in a repeatable workflow, preserving evidence context.
- Produced a structured forensic report documenting evidence and investigation findings.

Web Application Vulnerability Testing – Graduate Secure Software Engineering Project
OWASP ZAP | WebGoat | Kali Linux | SQL Injection | IDOR | SSRF | Path Traversal | Authentication Testing | HTTP Analysis

- Configured a controlled WebGoat testing environment on Kali Linux and used OWASP ZAP as an intercepting proxy to capture, inspect, modify, and replay HTTP requests and responses.
- Exploited string and numeric SQL injection scenarios to demonstrate unauthorized data disclosure, modification of database records, privilege-related SQL operations, and destructive database actions affecting confidentiality, integrity, and availability.
- Tested path traversal vulnerabilities by manipulating multipart file-upload paths and bypassing weak input-filtering controls, demonstrating why server-side path normalization and validation are required.
- Evaluated authentication and authorization weaknesses including password-reset bypasses, insecure credential transmission, and IDOR/BOLA by modifying client-controlled parameters and object identifiers to access unauthorized resources.
- Investigated insecure logging and sensitive-data exposure, including log injection/spoofing and credential leakage, and analyzed the resulting integrity and confidentiality risks.
- Demonstrated Server-Side Request Forgery (SSRF) by modifying a server-controlled URL parameter through ZAP and causing the vulnerable application to retrieve an unintended external resource.

Ethereum Marketplace DApp – *Graduate Blockchain Development Project*
Solidity | Ethereum Sepolia | MetaMask | Remix | JavaScript | Web3 | Smart Contracts | HTML/CSS

- Developed and deployed a decentralized marketplace smart contract in Solidity on the Ethereum Sepolia testnet, supporting item listing, purchasing, seller-controlled cancellation, and lifecycle states for Listed, Sold, and Cancelled items.
- Implemented smart contract state management using mappings, structs, enums, payable functions, and on-chain events, with validation controls for item ownership, listing status, transaction value, and seller/buyer restrictions.
- Built a browser-based frontend in JavaScript, HTML, and CSS to connect MetaMask wallets, interact with contract read/write functions, switch to the Sepolia network, and display active, sold, and cancelled marketplace listings.
- Integrated direct Ethereum JSON-RPC interactions for contract calls and transactions, including ABI data encoding/decoding, transaction submission, receipt monitoring, and error handling.
- Deployed and validated the contract through Remix and MetaMask and verified deployment and marketplace transactions using Sepolia blockchain explorer records.

PIPEDA Privacy & Security Case Analysis – *Graduate Academic Analysis*
PIPEDA | Privacy | Consent | Data Protection | Regulatory Analysis

- Analyzed Canadian privacy and security cases involving consent, hashed identifiers, data use, and organizational accountability under PIPEDA and Office of the Privacy Commissioner findings.
- Translated regulatory issues into practical privacy, governance, and risk considerations relevant to security and compliance functions.

Additional Engineering Projects

Windows Server & Active Directory Infrastructure – *Undergraduate Systems Administration Project*
Windows Server 2012 R2 | Active Directory | DNS | DHCP | Group Policy Concepts | VirtualBox | IIS | File Server | Access Control

- Designed and deployed a multi-server Windows domain environment in Oracle VirtualBox, including two Windows Server 2012 R2 systems and a Windows client connected through a private host-only network.
- Configured Active Directory Domain Services (AD DS) and DNS for a corporate domain, joined servers and client systems to the domain, and validated forward/reverse DNS resolution and inter-system connectivity.
- Created and organized 37 domain user accounts, Organizational Units (OUs), Global Security Groups, and Domain Local Groups based on organizational departments and administrative roles.
- Implemented role-based access control (RBAC) for departmental file shares using Active Directory security groups, restricting access to HR, Finance, IT, Supply Chain, Marketing, and Sales resources according to business requirements.
- Deployed and administered DHCP, File Server, Print Server, and IIS roles, including DHCP scope configuration, shared-resource permissions, network printer deployment, and internal web hosting.

Raspberry Pi Surveillance Robot – *Undergraduate IoT & Embedded Systems Project*
Raspberry Pi | Python | Linux | PiCar-X | Computer Vision | IoT | Face Detection | Remote Monitoring

- Developed and integrated Python-based control and surveillance functionality for a Raspberry Pi PiCar-X robotic platform, combining motor control, camera operation, computer vision, and remote monitoring.
- Implemented face and color detection using SunFounder Vilib and developed camera tracking logic that automatically adjusted pan/tilt angles to keep detected subjects within the camera's field of view.
- Built manual movement and camera controls, real-time video monitoring, and video recording/export functionality; enabled the robot to operate over a local network for remote surveillance and patrol scenarios.
- Collaborated on hardware/software integration and troubleshooting involving servos, camera modules, power, and Raspberry Pi components, and documented system implementation, testing, and project results.

Facial Recognition System – *Undergraduate Project*
Raspberry Pi | Python | OpenCV | Linux | Computer Vision | Face Recognition | Pi Camera

- Implemented a Raspberry Pi–based facial recognition system integrating a Pi Camera, Python, OpenCV, and Linux to capture images and perform live face identification.
- Built and configured the computer vision environment by compiling OpenCV 3.4.7 from source with Raspberry Pi ARM optimizations, configuring Python virtual environments, NumPy, system dependencies, and camera interfaces.
- Created facial image datasets from multiple viewing angles, trained the recognition workflow to generate reusable face encodings, and validated recognition through live camera input with labeled face detection.
- Coordinated a three-member team and documented hardware configuration, software deployment, testing procedures, and system implementation.

2D Multiplayer Space Shooter Game – *Undergraduate Software Development Project*
Processing | Java | Object-Oriented Programming | UML | FSM | ArrayList | Minim | 2D Game Development

- Collaborated in a three-member team to design and develop The War of Spacecraft, a 2D multiplayer space shooter featuring real-time keyboard controls, directional shooting, enemy combat, power-ups, level progression, and boss battles.
- Designed the application structure using UML class diagrams and a Finite State Machine (FSM), organizing gameplay components into reusable classes for players, enemies, projectiles, bosses, and power-up objects.
- Implemented event-driven gameplay using keyboard and mouse input, dynamic ArrayList collections, collision and movement logic, player health, scoring, difficulty progression, and multiple temporary power-up effects including shield, healing, increased speed, freeze, and additional ammunition.

- Developed multi-page user interfaces for game start, settings, help, and gameplay; integrated selectable backgrounds and player skins, configurable audio, image assets, and game-state transitions.

Smart Health System – *Undergraduate Software Project*
Front-End Development | UI Design | Software Testing

- According to project requirements and designed the appropriate user interface.
- Implemented user requested features based on functional requirements.
- Developed and tested all features and successfully made the software work.

Bookstore System – *Undergraduate Software Project*
Application Development | Database Design | Systems Analysis

- Developed user interface components and optimized user workflows across multiple platforms.
- Implemented the application on different platforms.

Education

Master of Science: Cybersecurity
New York Institute of Technology, Vancouver, BC | May 2026

- Relevant study: software security, digital forensics, web application security, network security, blockchain technologies, privacy, risk, and security governance.

Bachelor of Technology: Information Technology
Kwantlen Polytechnic University**,** Surrey, BC | *August 2024*

- Foundation in software development, web technologies, Data Mining, Database Management, systems analysis, UI/UX, networking, and team-based project delivery.

Certifications

Cisco Certified Network Associate: Routing and Switching (CCNA) – May 2020
Cisco Networking Academy